ROYAL HOLLOWAY, UNIVERSITY OF LONDON

MSc EXAMINATION 2021

IY5606: Smart Cards, RFIDs and Embedded Systems Security
IY5606R: Smart Cards, RFIDs and Embedded Systems Security

– for FIRSTSIT/RESIT CANDIDATES

Time Allowed: **TWO hours**

Please answer **THREE** questions

- Handwrite your answers on paper, and write your candidate number and the module number at the top of each page. Photograph/scan the pages and keep the original paper versions, as they may be required by the examiners.
- For each question you attempt, please clearly state the question number.
- Please DO NOT include your name or Student ID anywhere on your work.
- **Academic Misconduct:** We will check all submissions for academic misconduct. Suspected offences will be dealt with under the College's formal Academic Misconduct procedures. Please remember:
  - The work submitted is expected to be your own work and only your work. You may not ask for help from any source, or copy anyone else's work.
  - You must not give help to anyone else, including sending them any parts of the questions or copies of your solutions.
  - You must not discuss the questions or solutions with anyone else.
- **Submitting your work:**
  - Your document must be submitted through Moodle using the submission link in the module Moodle page. If possible please convert your document into a PDF document to make the submission process quicker and easier.
  - Emailed submissions will not be accepted.
  - **You must complete your exam upload within 1 hour of the exam finish time.**

Important Copyright Notice
This exam paper has been made available in electronic form
strictly for the educational benefit of current Royal Holloway students
on the course of study in question.
No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 1

Smart card technology

(a) Discuss the three main attack points of a smart card microprocessor. [3]

(b) Discuss three potential threats that could arise during the manufacturing of a smart card microprocessor. [3]

(c) Discuss the basic principles of timing attacks in smart card microprocessors and provide an example of such an attack. [4]

(d) Imagine you are developing a portable IoT device (e.g. a smart watch) that can be used for payment purposes in the public transport industry. What lessons have you learned from the mistakes of Mifare Classic and what security design decisions do you consider crucial for the development of such a product? [5]

(e) You are working for an IoT product developer and your department is responsible for the overall hardware design of the device. However, you are considering outsourcing the hardware manufacturing to a third country. Discuss the potential risks from hardware trojans infiltrating the hardware design and suggest potential detection methods. [5]

(f) Discuss the potential performance and implementation considerations when a contactless smart card with public key cryptographic capabilities is to be used as a ticketing medium in public transport. [5]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 2

A Subscriber Identity Module (SIM) is an essential component in the authentication and key agreement processes used to secure access to GSM mobile networks.

(a) GSM Device Security Essentials.

(i) What three things (consider data or functionality) are needed within a GSM SIM to identify it and authenticate to the network? [3]

(ii) Explain what is meant by the GSM A3 and A8 algorithm components and what outputs they generate. [4]

(iii) In GSM the mobile handset is regarded as less trustworthy than the SIM, but it needs access to the cipher key (Kc); how is this risk managed? [2]

(iv) Explain what is meant by the A5 algorithm components and whether they need to be the same in all GSM networks. [3]

(b) GSM System Security Essentials.

(i) Considering a mobile to mobile voice call, discuss the extent and strength of security protection offered by GSM (2G) authentication and encryption, and highlight the improvements made in the UMTS (3G) standards. [8]

(ii) In GSM the algorithm option, A5/0, means that wireless encryption is turned off. What are the relative strengths of A5/1 and A5/2 and why might attacking the weaker variant help to attack the stronger one? [5]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 3

Trusted Execution Environments (TEEs) and Attacks

(a) Describe two security properties provided by TEEs. [2]

(b) Provide two examples of TEE technologies. [2]

(c) Briefly describe the term 'remote attestation'. [2]

(d) Discuss how TEEs can enhance the security of fingerprint-based biometric authentication on mobile devices. [7]

(e) TEEs have been shown to be more susceptible to micro-architectural attacks and physical attacks than other secure execution platforms. Provide reasons why TEEs are particularly vulnerable to these attacks, and provide two examples of such attacks. [6]

(f) Compare and contrast the security-related properties of Intel SGX with ARM TrustZone. [6]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 4

Automotive Security, Internet-of-Things (IoT) and Computation on the Edge

(a) Suppose that, in country X, national payment industry fraud statistics indicate that Card-Not-Present (CNP) transaction fraud levels are on the increase. Discuss why this might be happening. [3]

(b) A smart car manufacturer is considering issuing security patches as quickly as possible through the use of USB devices that are sent out or self-downloaded. Discuss the potential security risks in such a proposed approach. [3]

(c) For many years the automotive industry provided bespoke software specifically developed for their dedicated hardware components. More recently there is a trend to move to "off-the-shelf" mechanisms and applications. Describe two advantages and two disadvantages of such an approach. [4]

(d) A smart car, having a large number of on-board sensors, is involved in a car accident. The police are required to perform a forensic investigation of the car sensors in order to obtain further evidence as to what exactly happened. Supposing you are a forensics investigator, describe the approach for conducting your analysis. [6]

(e) A number of organisations are advocating the introduction of IoT devices that have internet connectivity and perform all computationally expensive operations in the cloud. Discuss the potential advantages and disadvantages of such an approach. [5]

(f) A number of devices, e.g. the "Cayla" doll, have a limited number of sensors (e.g. a microphone and a speaker) and require connectivity with a mobile application to perform further processing. Discuss whether these devices should be considered as part of the IoT. [4]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 5

Imagine you are an information security consultant specialising in smart cards, tokens, security, and applications. You have been assigned a project that requires the provision of expert advisory services for a major national payment scheme.

The national payment scheme has an extensive card and mobile phone cardholder base, that are involved in the majority of the country's card-present and card-not-present (CNP) transactions. The scheme is also well known for being innovative in enhancing the payment experience of its cardholders, e.g. it was the first to offer Near Field Communication (NFC) payments. In order to remain ahead of the payment scheme competition, the national scheme wishes to further enhance financial transaction speed and security. Currently, they would like to enhance the customer's experience at the point-of-sale (POS).

You have been asked to provide a plan taking into consideration new technologies that will allow them to realise this vision. Amongst the main technologies that have been proposed is the introduction of cardholder biometrics, i.e. not using the card/NFC tokens during payment transactions. More specifically, they are considering the use of cardholder face recognition as the transaction authorisation method.

(a) Describe your recommendations for an overall system design for conducting financial transactions at physical stores and the POS. Your analysis should include a diagram of your proposed system infrastructure. This should clearly identify the current entities involved and their roles, the current processes, the operational and security characteristics, the back office systems, and any other elements that you consider important for the successful deployment of such a system. [13]

(b) Describe whether the proposed solution can work in CNP transactions. [2]

(c) Describe the modifications to the existing Europay-Mastercard-Visa (EMV) protocol that are required in order to support the proposed biometrics-based architecture. [4]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

(d) Summarise three potential advantages of your recommended solution when compared to the existing PIN verification method for card and NFC payment transactions. [3]

(e) Describe fall-back procedures for use if the new system fails to operate as expected. [3]

END

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.